

A Phishing Incident Investigation Report

TARGET: M  re Healthcare

Chinonso Eneje

1.0 Executive Summary

This report presents the findings of an investigation into a phishing attack targeting MediSure Healthcare. MediSure runs an integrated healthcare network in Los Angeles. The investigation focused on analysing the malicious email, validating its authenticity, examining the embedded links and infrastructure used by the attacker, reviewing network and authentication logs, and determining the extent of compromise.

The analysis revealed multiple indicators confirming that the email was malicious, including failed SPF and DKIM authentication, the absence of a DMARC policy, suspicious sender infrastructure, malicious embedded content, and evidence that two employees interacted with the phishing email. Splunk log analysis further confirmed that one user account had already been compromised, requiring immediate containment.

The investigation demonstrates how a single phishing email can progress from initial delivery to credential compromise if not detected early, reinforcing the importance of layered email security, user awareness training, and rapid incident response.

2.0 Introduction

MediSure manages Hospitals, Clinics, Specialty centers, and Telemedicine platforms, and it has an integrated electronic Health Records across all facilities. Phishing remains one of the most common methods used by cybercriminals to gain unauthorised access to organisational systems. Attackers frequently impersonate trusted organisations to deceive users into revealing sensitive information or installing malware.

This investigation was conducted following the identification of a suspicious email received by MediSure Healthcare. The objective was to determine whether the email represented a genuine security threat, identify indicators of compromise (IOCs), establish the extent of user interaction, and recommend appropriate response actions.

Incident

A phishing email impersonating a Microsoft security notification was delivered to MediSure Healthcare employees. Technical analysis indicated multiple authentication failures, suspicious sender infrastructure, malicious embedded content, and evidence of user interaction with the phishing website.

Risk

The primary risks associated with this incident include:

Credential theft, Unauthorised access to Microsoft 365 accounts, Data breach involving sensitive patient information, Malware delivery, Lateral movement within the organisation, Business disruption, Regulatory and reputational damage.

3.0 Objectives

The objectives of this investigation were to:

1. Verify whether the email was malicious.
2. Identify indicators of compromise.

3. Analyse email authentication records (SPF/DKIM/DMARC).
4. Examine embedded URLs and infrastructure.
5. Investigate user interaction through security logs.
6. Determine whether any user accounts had been compromised.
7. Recommend containment and remediation measures.

4.0 Methodology

The investigation followed a structured incident response methodology based on recognised cybersecurity investigation practices. Email header analysis was done using MXToolBox, Sender verification, Authentication validation, URL inspection, Threat intelligence lookups, was done using Virustotal, AbuseipDB, AlienVault. Log analysis was done using Splunk Enterprise.

4.1 Incident Response Execution

After reviewing the email header, analysing SMTP routing information, validating SPF, DKIM and DMARC records, Investigating sender IP reputation, examining embedded links. Querying VirusTotal, AbuseIPDB, AlienVault and MXToolbox, reviewing Splunk proxy, firewall and authentication logs. Affected systems were Identified and isolated accordingly.

4.2 Technology Stack

The following tools were used throughout the investigation:

<u>Tool</u>	<u>Purpose</u>
MXToolbox	Email header analysis
VirusTotal	URL, domain and file reputation
AbuseIPDB	IP reputation analysis
AlienVault OTX	Threat intelligence
Splunk Enterprise	Log analysis
Microsoft 365 Logs	Authentication investigation

5.0 Key Findings

The investigation identified multiple indicators confirming that the email was part of a phishing campaign targeting MediSure Healthcare.

5.1 Initial Email Review

Initial inspection revealed several suspicious characteristics.

Key observations included:

Reply-To address used a Gmail account instead of a corporate domain.
The sender infrastructure differed from legitimate Microsoft infrastructure.
Delivery time exceeded 3,800 seconds, significantly longer than expected.
Multiple authentication failures were identified.



Microsoft account team <no-reply@access-accsecurity.com>

To: employee@medisurehealthnetwork.com



Wed 8/16/2

We detected something unusual about a recent sign-in to the Microsoft account

Sign-in details:

- **Country/region:** Russia
- **IP address:** 103.225.77.255
- **Date:** Wed, 16 Aug 2023 00:05:41 GMT
- **Platform:** Windows
- **Browser:** Chrome

If this was you, you can safely ignore this email. If not, we recommend that you [secure your account](#) immediately.

Figure 01 : Email body and indicators.

The following indicators of compromise were identified:

Originating IP: 89.144.44.41

Mail server: mail.access-accesssecurity.com

Reply-To address: solutionteamrecognizd03@gmail.com

These findings strongly suggested that the email was spoofed.

5.2 Domain and Authentication Checks

Authentication analysis identified several critical failures.

The investigation found:

No DMARC policy published.

SPF authentication failed.

SPF alignment failed.

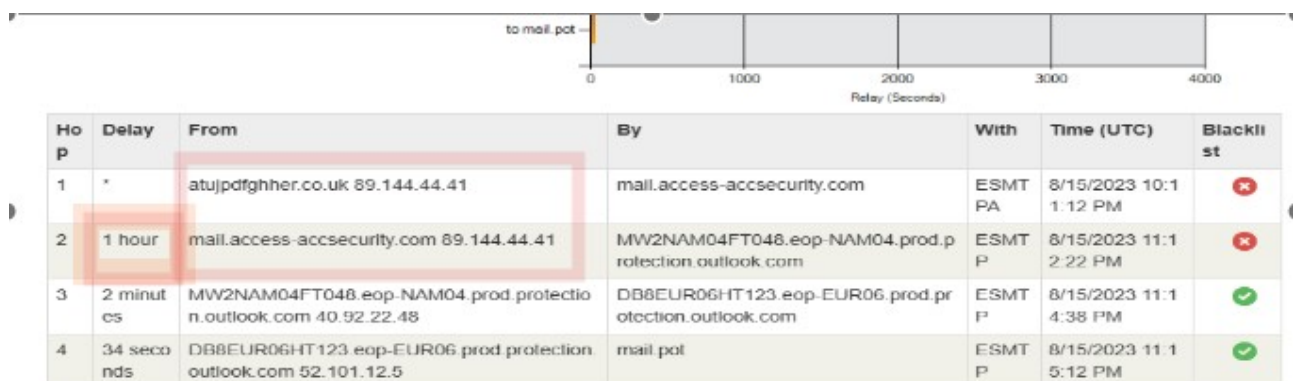
DKIM authentication failed.

DKIM alignment failed.

Sender IP was not authorised to send email for the claimed domain.

Sender infrastructure had been blacklisted.

Mail path: 4 hops with ~1 hour dwell between hop 1 and 2



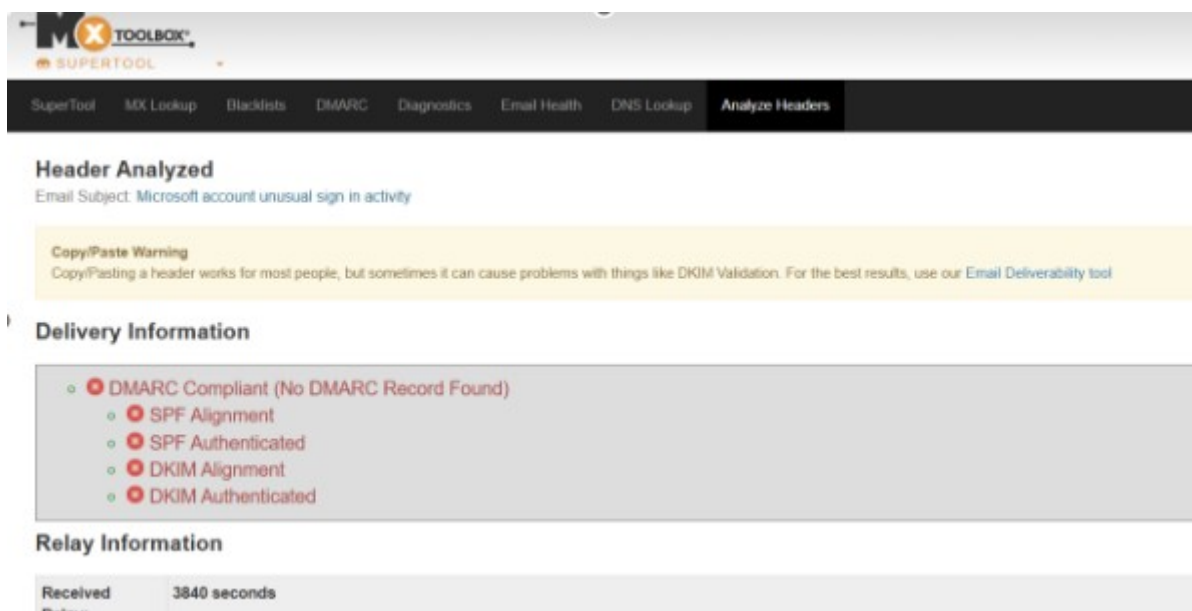


Figure 02: MXToolbox SPF/DKIM/DMARC summary

These authentication failures indicate that the sender could not be trusted and that the email had likely been spoofed.

5.3 Link and Attachment Scanning

Multiple threat intelligence platforms were used to assess the embedded infrastructure.

Key findings included:

Sender IP locations varied across threat intelligence platforms.

A second IP address (103.225.77.255) had previously been reported numerous times for malicious activity.

VirusTotal identified embedded files associated with the infrastructure.

The tracking pixel source (thebandalisty.com) was flagged as malicious by multiple security vendors.

The embedded "Secure Your Account" hyperlink redirected users to sign.in, a phishing page previously reported as malicious.

AlienVault identified numerous passive DNS records and related URLs associated with the malicious domain.

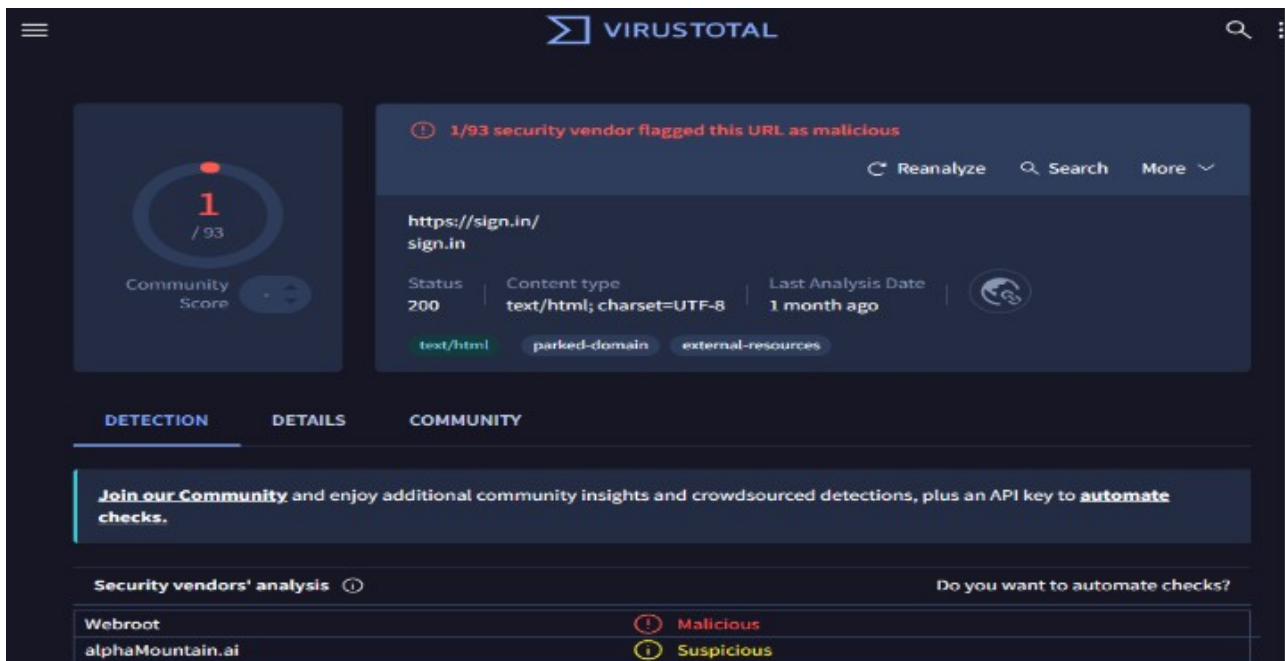


Figure 03: VirusTotal detections for domains/URLs.

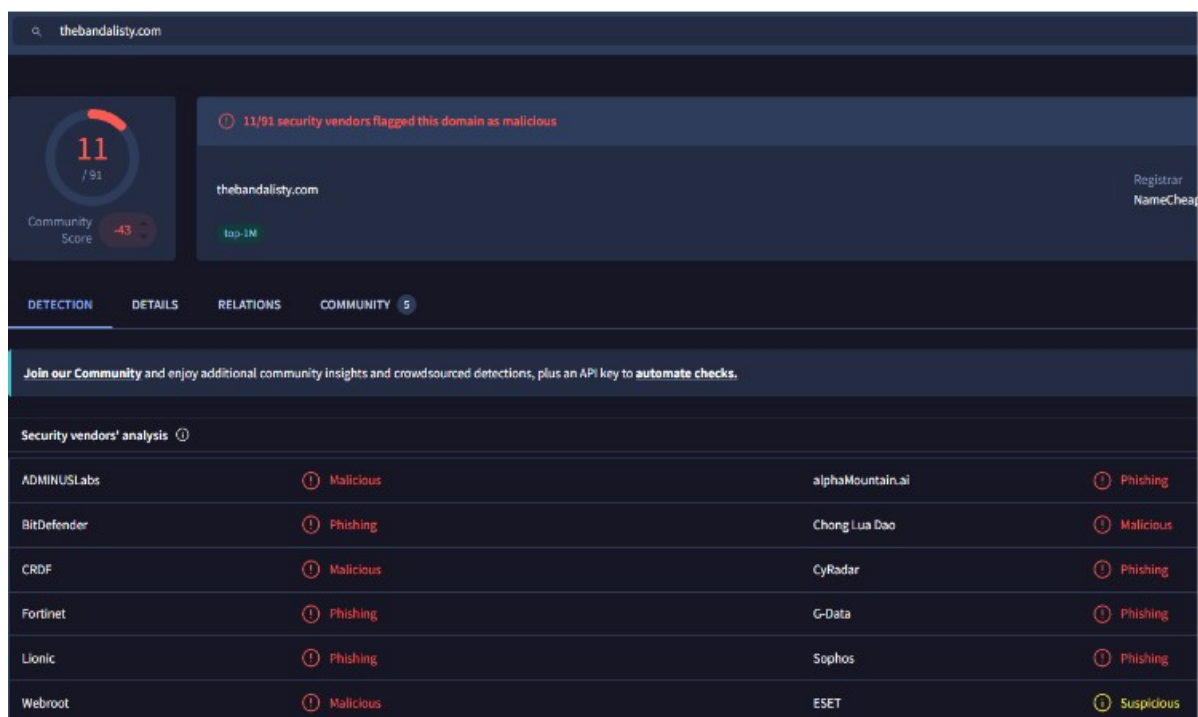


Figure 04: VirusTotal flagging the pixel source(thebandalisty.com) as malicious

5.4 Network Traffic Analysis with Splunk

Splunk was used to determine whether employees interacted with the phishing campaign. Proxy, firewall, and authentication logs were analysed.

Domains: sign.in, access-accsecurity.com, thebandalisty.com

IPs: 89.144.44.41, 103.225.77.255

5.4.1 Proxy Logs (User Clicks)

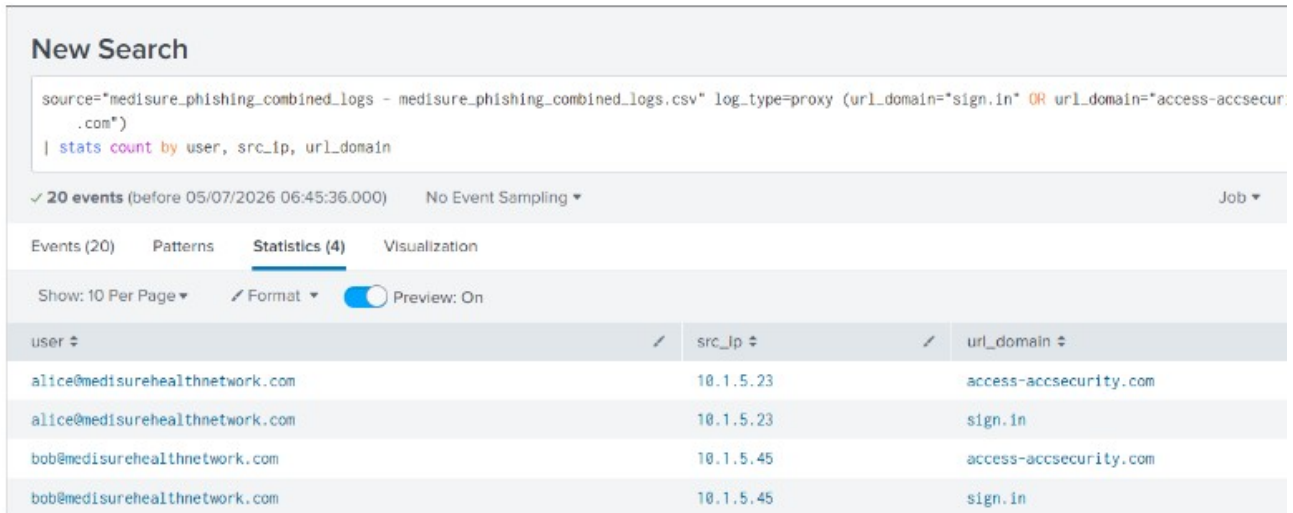
Proxy logs showed that two employees:

Alice (10.1.....3)

Bob (10.1.....5)

visited the phishing website(sign.in and access-accsecurity.com.).

This confirms successful user interaction with the phishing email.



New Search

source="medisure_phishing_combined_logs - medisure_phishing_combined_logs.csv" log_type=proxy (url_domain="sign.in" OR url_domain="access-accsecurity.com")
| stats count by user, src_ip, url_domain

✓ 20 events (before 05/07/2026 06:45:36.000) No Event Sampling ▾ Job ▾

Events (20) Patterns **Statistics (4)** Visualization

Show: 10 Per Page ▾ Format ▾ Preview: On

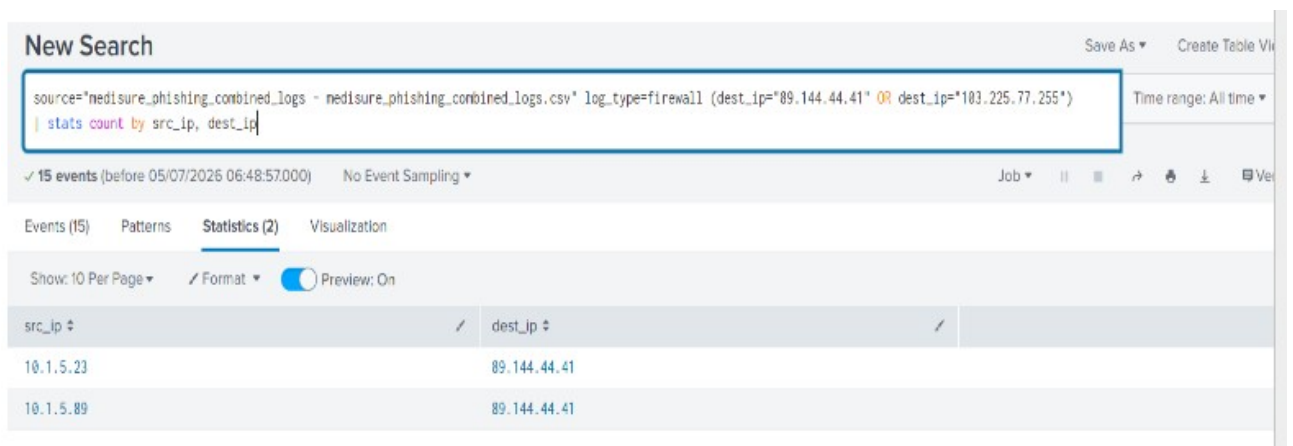
user	src_ip	url_domain
alice@medisurehealthnetwork.com	10.1.5.23	access-accsecurity.com
alice@medisurehealthnetwork.com	10.1.5.23	sign.in
bob@medisurehealthnetwork.com	10.1.5.45	access-accsecurity.com
bob@medisurehealthnetwork.com	10.1.5.45	sign.in

Figure 05: image showing users (Alice and Bob) who visited the website

5.4.2 Firewall Logs (Connections to Attacker)

Firewall logs confirmed repeated communication between the affected users and the malicious infrastructure. The internal machines 10.1.....3 and 10.1.....5 connected to 89.144.44.41 which is the originating IP of the phishing email.

Repeated connections significantly increased the likelihood of credential compromise and malware execution.



New Search

source="medisure_phishing_combined_logs - medisure_phishing_combined_logs.csv" log_type=firewall (dest_ip="89.144.44.41" OR dest_ip="103.225.77.255")
| stats count by src_ip, dest_ip

✓ 15 events (before 05/07/2026 06:48:57.000) No Event Sampling ▾ Job ▾ || ▢ ↗ ⚙ ⬇ 📄 Ver

Events (15) Patterns **Statistics (2)** Visualization

Show: 10 Per Page ▾ Format ▾ Preview: On

src_ip	dest_ip
10.1.5.23	89.144.44.41
10.1.5.89	89.144.44.41

Figure 06: Firewall logs - Internal hosts (██████████, ██████████) connected to 89.144.44.41.

5.4.3 Authentication Logs (Credential Attempt)

Authentication logs showed that:

Bob's account was accessed from Russia.

The attacker attempted to authenticate using Bob's credentials.

This provides strong evidence that Bob's credentials had been compromised.

New Search

source="medisure_phishing_combined_logs - medisure_phishing_combined_logs.csv" log_type=auth location="Russia"
| stats count by user, result, location

✓ 5 events (before 05/07/2026 07:24:46.000) No Event Sampling ▼

Events (5) Patterns **Statistics (1)** Visualization

Show: 10 Per Page ▼ Format ▼ Preview: On

user ↕	result ↕	location ↕
bob@medisurehealthnetwork.com	Failure	Russia

Figure 07: image showing that Bob connected to the attacker infrastructure.

5.4.5 Implications

The investigation indicates that:

1. Credentials were likely harvested.
2. At least one user account was compromised.
3. The attacker gained initial access.
4. There was a risk of lateral movement.
5. Sensitive healthcare information may have been exposed (though, no data exfiltration detected).
6. Further compromise was likely without immediate intervention.

6.0 Incident Response and Mitigation

6.1 Containment

Immediate containment actions included:

1. Isolating Bob's workstation from the network.
2. Disabling compromised accounts.
3. Blocking malicious domains and IP addresses(Block access-accsecurity.com, sign.in, thebandalisty.com, and IPs 89.144.44.41 / 103.225.77.255 across email gateway, firewall, and DNS filtering.
4. Removing phishing emails from all mailboxes.

6.2 Eradication & Remediation

Recommended remediation activities included:

1. Resetting passwords for Alice and Bob, and enabled Multi-Factor Authentication (MFA). Revoking active Microsoft 365 sessions.

2. Updated SIEM correlation searches to flag misaligned headers, missing SPF/DKIM/DMARC, and outbound traffic to flagged domains/IPs.
3. Removing malicious inbox rules.
4. Updating endpoint protection.
5. Conducting organisation-wide phishing awareness training.

6.3 Recovery

Recovery activities included:

1. Restoring secure user access for Alice and Bob.
2. Continuous Monitoring authentication logs.
3. Verifying system integrity after forensic validation.
4. Performing vulnerability assessments.
5. Established enhanced monitoring for both users and hosts, Configure Splunk to trigger alerts on suspicious login geolocations and IOC traffic

6.4 Lessons Learnt and Integrated into SOC Playbooks

The investigation highlighted several improvements for MediSure's Security Operations Centre:

1. Improved email authentication enforcement through DMARC implementation.
2. Strengthened email filtering policies.
3. Increased employee phishing awareness.
4. Enhance detection rules within Splunk, through Proxy/DNS telemetry enrichment standardized for user-host-destination correlation.
5. Improved threat intelligence integration by adding immediate session revocation SOP for suspected credential compromise.

7.0 Risk & Impact Assessment

Risk

Credential compromise
 Patient data exposure
 Business disruption
 Malware infection
 Regulatory penalties
 Reputational damage

Impact

Critical(due to potential exposure)
 Low (no evidence of tampered records)
 Low (no downtime recorded with-respect to this attack)
 Low (no malware infection identified)
 None
 None

Immediate Actions

The following actions should be prioritised:

Quarantine Bob's workstation.
 Reset affected user (Alice and Bob) passwords.
 Force Microsoft 365 session revocation.
 Enable MFA for all users.
 Block attacker infrastructure.
 Conduct organisation-wide phishing awareness communication.
 Continue forensic monitoring.

8.0 Ongoing Monitoring

MediSure Healthcare should ensure to establish Splunk alerts for; Suspicious Microsoft 365 logins, New inbox rules, Password reset attempts, Unusual outbound connections, Endpoint malware alerts. Repeat phishing campaigns.

Threat intelligence feeds should also be continuously updated to detect emerging phishing infrastructure.

Conclusion

The investigation confirmed that the suspicious email was a sophisticated phishing attempt designed to steal Microsoft 365 credentials. Multiple technical indicators, including failed email authentication, malicious infrastructure, suspicious embedded links, and threat intelligence **findings**—verified the legitimacy of the threat. Splunk log analysis further demonstrated that two employees interacted with the phishing website, while authentication logs confirmed that one user account had already been compromised.

Prompt incident response actions, including account isolation, password resets, and enhanced monitoring, were carried out to minimise further damage. Stakeholders were alerted accordingly. Going forward, MediSure Healthcare has strengthened its email security controls, enforced DMARC, expanded user awareness training, and continuously refine SOC detection and response capabilities to reduce the likelihood and impact of future phishing attacks.

References

MITRE ATT&CK. ATT&CK Framework – Phishing (T1566).
National Institute of Standards and Technology. Computer Security Incident Handling Guide (SP 800-61 Rev. 2).
Cybersecurity and Infrastructure Security Agency. Phishing Guidance and Best Practices.
VirusTotal Threat Intelligence.
AbuseIPDB Reputation Database.
AlienVault Open Threat Exchange (OTX).
MXToolbox Email Header Analyzer.
Splunk Enterprise Log Analysis.
Investigation evidence collected from the MediSure Healthcare phishing incident.